



Government  
of Canada

Gouvernement  
du Canada

## **ESDC Development Community**

# **GitHub Actions**

*Le texte français est donné à la suite.*

## **Background**

This page means to bring attention to a few features available to projects on GitHub.com for pipeline and code security needs. Where in the past we needed to rely on external tools (like travis-ci or circle-ci), since 2018 GitHub has been ramping up its own pipeline features such as GitHub Actions, Dependabot and Code Scanning.

## **GitHub Actions/Pipelines**

Like Gitlab and Azure DevOps, you can have GitHub perform Continuous Integration pipelines to build your applications and run tests on every push/Pull Request/merge to catch problems early. Github Actions can also be used for Continuous Delivery to deploy your application to cloud services or binary repositories (such as Nuget or Maven central), either triggered manually or automatically when a release is created. GitHub has action runners available supporting most commonly used programming languages on either Windows or Linux infrastructure.

To get started, you can simply go to the "Actions" tab in your GitHub repository. GitHub has good documentation on GitHub Actions, its workflows and their syntax.

A few additional notes:

- If your pipeline needs secrets (API keys, passwords, etc) it is important that they not be present directly in your workflow script or anywhere else in your Git source repository.
  - If needed for deployment, you can create new "environments" for your project in Github and use them to store secrets. Environments can also be used to add an approval step for deployment.
  - If secrets are needed for your CI or other generic builds, they can be stored as "repository secrets".
- Hosting your own Github action runner is **not** recommended. Pipeline scripts run on branches before PR approval, which means anyone with the ability to create a Pull Request in your main repository can modify the pipeline script to run arbitrary code on the runner, which obviously is a security risk. If absolutely necessary, self-hosted runners should run in a security-hardened and/or throw-away environment (like a docker container that gets recycled on every run)

## Dependabot and Code Scanning

Two other recommended features of GitHub are Dependabot and code scanning.

Dependabot can warn you of security vulnerabilities discovered in the libraries your project depends on. It can also be used to periodically/automatically update your project's dependencies (when coupled with proper automated testing, auto-updating of dependencies is not as scary as it sounds). Refer to [GitHub's Dependabot Documentation](#) for details.

GitHub can also detect vulnerabilities in your own source code by setting up code scanning. This, like dependabot alerts can be enabled in the "Security" tab of your repository. Refer to [GitHub's Code Scanning Documentation](#) for details.

---

*Texte français:*

Quelques notes sur les fonctionnalités des actions GitHub

## Contexte

Cette page vise à attirer l'attention sur certaines fonctionnalités offertes aux projets sur GitHub.com pour répondre aux besoins de pipelines et de sécurité du code. Alors qu'auparavant nous devions nous appuyer sur des outils externes (tels que Travis-CI ou CircleCI), GitHub a développé ses propres fonctionnalités de pipeline depuis 2018, comme GitHub Actions, Dependabot et l'analyse de code (Code Scanning).

## GitHub Actions / Pipelines

Tout comme GitLab et Azure DevOps, vous pouvez utiliser GitHub pour exécuter des pipelines d'intégration continue afin de compiler vos applications et d'exécuter des tests à chaque push/Pull Request/fusion pour détecter les problèmes au plus tôt. GitHub Actions peut également être utilisé pour la livraison continue afin de déployer votre application sur des services infonuagiques ou des référentiels de binaires (comme NuGet ou Maven Central), soit manuellement, soit automatiquement lors de la création d'une version. GitHub fournit des exécuteurs (runners) prenant en charge la plupart des langages de programmation courants sur les infrastructures Windows ou Linux.

Pour commencer, accédez simplement à l'onglet « Actions » de votre référentiel GitHub. GitHub offre une excellente documentation sur [GitHub Actions](#), ses [flux de travail \(workflows\)](#) et leur [syntaxe](#).

Quelques remarques supplémentaires :

- Si votre pipeline requiert des secrets (clés API, mots de passe, etc.), il est crucial qu'ils ne soient pas codés directement dans vos scripts de workflow ou dans votre code source Git.
  - Au besoin pour le déploiement, vous pouvez configurer des « environnements » dans GitHub et y stocker des secrets. Les environnements permettent également d'ajouter une étape d'approbation préalable au déploiement.
  - Si les secrets sont nécessaires pour la CI ou des compilations génériques, ils peuvent être stockés sous forme de « repository secrets ».
- L'hébergement de votre propre exécuteur (self-hosted runner) **n'est pas** recommandé. Les scripts de pipeline s'exécutent sur les branches avant l'approbation de la PR, ce qui signifie que toute personne autorisée à ouvrir une Pull Request dans votre référentiel peut modifier le script pour exécuter du code arbitraire sur l'exécuteur, ce qui constitue un risque de sécurité. Si cela est absolument nécessaire, les exécuteurs auto-hébergés doivent s'exécuter dans un environnement sécurisé et/ou jetable (comme un conteneur Docker réinitialisé à chaque exécution).

## Dependabot et analyse de code (Code Scanning)

Deux autres fonctionnalités recommandées de GitHub sont Dependabot et l'analyse de code.

Dependabot peut vous alerter sur les vulnérabilités de sécurité découvertes dans les bibliothèques dont dépend votre projet. Il peut également mettre à jour automatiquement et périodiquement vos dépendances (combiné à des tests automatisés rigoureux, la mise à jour automatique des dépendances est une approche très efficace). Consultez la [documentation de Dependabot](#) pour plus de détails.

GitHub peut également détecter les vulnérabilités dans votre propre code source en activant l'analyse de code (Code Scanning). Cette fonctionnalité, tout comme les alertes Dependabot, peut être activée dans l'onglet « Security » de votre référentiel. Consultez la [documentation sur l'analyse du code](#) pour plus de détails.